


**1 · Portada** · Sergio · ≈ 15 s

**Sergio:** Buenos días, profesor. Somos Sergio Montoya, Nicolás Torres y Oscar Rincón, del grupo 30112. Presentamos Rastro, un sistema de trazabilidad de envíos desplegado en AWS, en los siete bloques que usted pidió.

INDICACIÓN Cinco segundos. Mirar al jurado, no a la pantalla.

BLOQUE 1 · PRESENTACIÓN DEL SISTEMA

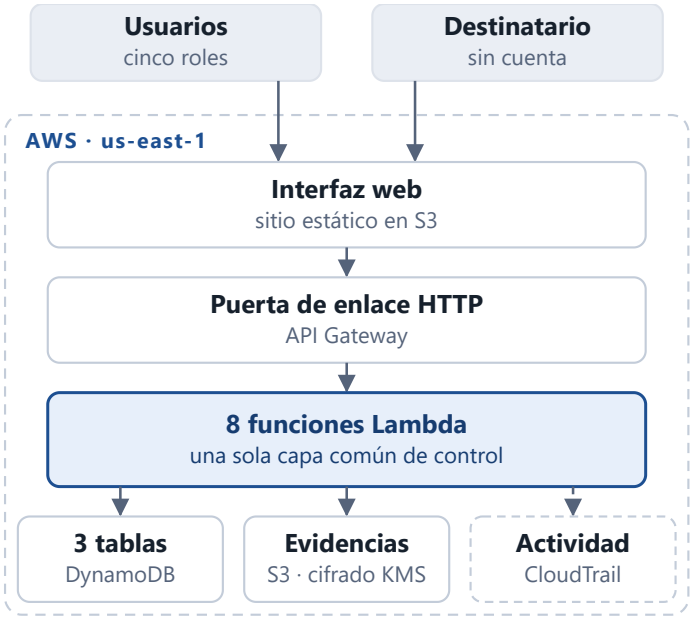
# El problema y el sistema

**Hoy.** En una mensajería urbana pequeña de Bogotá, el estado de un envío vive en la memoria del mensajero, un chat, una hoja de cálculo y el teléfono del despachador.

**Nadie puede decir quién cambió el estado, cuándo y con qué respaldo.**

**Rastro** obliga a que cada cambio quede **atribuido, fechado y validado** contra las transiciones permitidas.

AWS `us-east-1`: ocho funciones, tres tablas, almacén cifrado y registro de actividad. Varias empresas, datos aislados.






## 2 · El problema y el sistema · Sergio · ≈ 35 s

**Sergio:** Hoy, en una mensajería pequeña, el estado de un envío está repartido entre el mensajero, un chat, una hoja de cálculo y el teléfono. Falta un registro de quién lo cambió, cuándo y con qué respaldo. Rastro es ese registro: cada cambio queda atribuido, fechado y validado, y un envío no se salta pasos. Corre en AWS con ocho funciones Lambda, tres tablas y un almacén cifrado, y varias empresas lo comparten sin ver datos ajenos.

**INDICACIÓN** Señalar la figura de arriba abajo, sin recorrer caja por caja.

**SI PREGUNTAN** ¿Por qué importa? Sin ese registro, las reclamaciones se resuelven por acuerdo y la empresa asume el costo; el despachador pierde tiempo reconstruyendo información por teléfono, y no se puede acreditar ante un cliente que el procedimiento se cumplió. La evidencia del problema viene de la experiencia laboral del equipo: es observación no sistemática, y así está declarada en el documento. Cuenta `484948252891`.

BLOQUE 2 · PLANIFICACIÓN

# Objetivo, alcance y plan

**Objetivo.** Registrar de forma **verificable** el ciclo de vida de cada envío, con acceso por rol, aislamiento entre organizaciones y evidencia cifrada.

| Fase | Semanas | Responsable |
|---|---|---|
| **Diagnóstico y validación de supuestos** | 1–2 | Oscar Rincón |
| **Diseño** | 3–4 | Sergio Montoya |
| **Construcción y despliegue** | 5–9 | Nicolás Torres · Sergio Montoya |
| **Verificación y cierre** | 10–12 | Oscar Rincón |

**Fuera del alcance:** rastreo continuo del vehículo, rutas, aplicación nativa, notificaciones.
**Recursos:** 50 dólares por cuenta; único cargo fijo, la llave de cifrado.
**Declarado como no logrado:** retención inmutable del almacén.



### 3 · Objetivo, alcance y plan · Sergio · ≈ 30 s

**Sergio:** El objetivo fue registrar de forma verificable el ciclo de vida de cada envío: no basta con que funcione, cualquiera debe poder comprobarlo. Fueron doce semanas en cuatro fases, con un responsable cada una. Dejamos fuera el rastreo continuo, que además vigilaría al trabajador. Con cincuenta dólares, solo la llave de cifrado cobra fijo. Y declaramos lo no logrado: la retención inmutable, que el laboratorio no permitió.

**SI PREGUNTAN** Los cuatro objetivos específicos son uno por fase: caracterizar el proceso actual, diseñar arquitectura y modelo de datos, construir y desplegar sobre servicios gestionados, y verificar con pruebas que los controles funcionan. Dentro del alcance: identificador no predecible, consulta pública sin cuenta, evidencia cifrada, aislamiento, autorización por rol con registro del intento, bitácora encadenada y despliegue reproducible. Actividades: once decisiones de arquitectura registradas, ocho servicios, dos interfaces, 238 pruebas y despliegue verificado el 26 de septiembre. El riesgo del presupuesto no es el uso, que es marginal, sino dejar encendido un recurso que factura sin usarse.

BLOQUE 3 · METODOLOGÍA

# Metodología y técnicas

Enfoque **iterativo e incremental**: una fase por objetivo.

> **Ningún requisito se dio por cumplido antes de tener su prueba automatizada.**

| Técnica | Por qué esa |
|---|---|
| **Decisiones de arquitectura registradas antes de implementar** | Código y documento no se contradicen |
| **Prueba mínima de cada capacidad del laboratorio** | Comprobar antes de construir encima |
| **Pruebas unitarias y de extremo a extremo** | Reglas y requisitos, sin credenciales |
| **Verificación posterior al despliegue** | Lo desplegado existe y responde |
| **Auditoría independiente** | Quien despliega no concluye que su control funciona |



## 4 · Metodología y técnicas · Nicolás · ≈ 25 s

**Nicolás:** Gracias, Sergio. Trabajamos de forma iterativa, con una regla: ningún requisito se cerró sin su prueba automatizada. Registramos cada decisión antes de implementarla, probamos cada capacidad del laboratorio antes de construir encima y verificamos lo desplegado. Y la técnica clave: una auditoría independiente, porque quien despliega no debería concluir que su control funciona.

**INDICACIÓN** La auditoría es un programa externo, Cotejo, no una prueba más del equipo.

**SI PREGUNTAN** ¿Por qué no un marco ágil completo? Tres personas con dedicación parcial no sostienen sus ceremonias; lo que sí sostuvimos fue la regla de la prueba, y por eso la cobertura no cayó cuando el alcance creció. Las pruebas de extremo a extremo se organizan por requisito, no por módulo.

BLOQUE 4 · RIESGOS Y CONTROLES

# Riesgos y controles

| Riesgo | Prob. | Impacto | Respuesta | Estado |
|---|---|---|---|---|
| **Consulta sin filtrar por organización** | Media | Muy alto | Clave `ORG#…#ENV#…` · control C-06 | No materializado |
| **Exposición de secretos** | Media | Muy alto | Rotación y control C-09 | **Materializado y corregido** |
| **El laboratorio bloquea un servicio** | Media | Alto | Puerta de enlace | Materializado y resuelto |
| **El alcance crece y no se termina** | Alta | Alto | Regla de la prueba | Materializado y gestionado |
| **Se agota el presupuesto** | Media | Alto | Nada que facture entre sesiones | No materializado |

**Otros controles:** autorización por operación (C-05), bitácora encadenada (C-08), cifrado con llave propia (C-02, C-03), identificadores aleatorios.
**Faltan, porque el entorno lo impide:** rol de ejecución por función y ancla de integridad fuera de la cuenta.



## 5 · Riesgos y controles · Nicolás · ≈ 35 s

**Nicolás:** Los dos riesgos de impacto muy alto son ver datos de otra empresa y exponer secretos. El primero lo impide el diseño: sin el identificador de la organización, la consulta ni se puede construir. Tres riesgos se materializaron: el secreto, que Oscar desarrolla; el bloqueo de un servicio, resuelto con la puerta de enlace; y el alcance, contenido con la regla de la prueba. Y declaramos dos controles que el entorno no permite.

**SI PREGUNTAN** Activos protegidos: datos de envíos y destinatarios, evidencias de entrega, bitácora, llave de cifrado y secreto de firma de sesiones. El sistema solo tiene datos sintéticos: ningún dato personal real entró. Entre organizaciones responde 404 y no 403, porque un 403 confirmaría que el envío existe. Sin roles por función, las ocho comparten un rol amplio e incumplen mínimo privilegio; sin ancla externa, frente a quien administra la cuenta hay detección, no prevención. Otro riesgo, no materializado: un identificador literal que impida migrar de cuenta.

BLOQUE 4 · RIESGOS Y CONTROLES

# Roles y separación de funciones

| Rol | Puede | No puede |
|---|---|---|
| **Administrador** | Todo: envíos, catálogos, cuentas y roles | **Leer la bitácora** |
| **Coordinador** | Despachar, reanudar incidencias, editar catálogos | Administrar cuentas |
| **Despachador** | Crear y asignar envíos, registrar eventos | Reanudar incidencias |
| **Conductor** | Ver **sus** envíos, marcar avance, cargar evidencia | Crear o asignar envíos |
| **Auditor** | Consultar y **leer la bitácora** | Cualquier escritura |

**Ningún rol ni cuenta combina escritura con lectura de la bitácora.** No es configurable.
**Quien detiene un envío no es quien lo reanuda.** Nadie concede un permiso que no tiene.



## 6 · Roles y separación de funciones · Nicolás · ≈ 30 s

**Nicolás:** Hay cinco roles de fábrica, y la tabla sale del código. La regla central es la separación de funciones: el administrador puede todo menos leer la bitácora, y el auditor la lee sin escribir nada; ninguna cuenta suma las dos cosas. Quien detiene un envío no lo reanuda, y quien intenta darse un permiso que no tiene queda registrado. Oscar sigue con la normativa.

**SI PREGUNTAN** De 19 operaciones: Administrador 17, Coordinador 12, Despachador 9, Conductor 6 y Auditor 8; al administrador le faltan justo leer la bitácora y verificar su integridad. Los roles viven en datos: una empresa puede crear los suyos, pero solo eligiendo de la lista de operaciones. El rol de administrador no se edita, para que un error no deje a la empresa sin quien lo corrija. Sin permiso de asignar, solo se actúa sobre los envíos propios. La separación se comprueba sobre la suma de roles de la cuenta. Pruebas en `tests/e2e/test_roles.py` y `tests/unit/test_autorizacion_y_claves.py`.

BLOQUE 5 · NORMATIVAS

# Normativas y cumplimiento

| Marco | Cómo se cumple |
|---|---|
| **Ley 1581 de 2012** | Minimización, cifrado, acceso por rol; solo datos sintéticos |
| **ISO/IEC 27001:2022** | Llave propia con rotación; versionado |
| **CIS AWS Benchmark** | Registro con validación de integridad; sin acceso público |
| **OWASP Top 10:2021 A01** | Identificadores aleatorios; 404 y no 403 entre organizaciones |
| **NIST SP 800-92** | Bitácora con actor, acción, recurso y momento |
| **AWS Well-Architected** | **Mínimo privilegio: no se cumple** |

Auditoría independiente contra el sistema desplegado:






## 7 · Normativas y cumplimiento · Oscar · ≈ 25 s

**Oscar:** Gracias, Nicolás. Aplicamos seis marcos: la Ley 1581, ISO 27001, CIS, OWASP y NIST. La última fila va a propósito: el mínimo privilegio que pide AWS no se cumple, y lo ponemos junto a lo que sí. Esto no lo afirmamos solo nosotros: una auditoría independiente evaluó once controles. Diez conformes, uno desviado y ninguno sin ejecutar.

**INDICACIÓN** Nombrar los marcos sin leer la tabla y detenerse en la última fila.

**SI PREGUNTAN** Ley 1581 con el Decreto 1377; ISO 27001 en A.8.24, criptografía, y A.8.13, copias. El desviado es un secreto que sigue en el historial del repositorio, ya invalidado. El mínimo privilegio no se puede corregir en este entorno: el laboratorio no permite crear roles.

BLOQUE 6 · HALLAZGOS Y EVIDENCIAS

# Evidencias y hallazgo principal

| 234 | 4 | 0 | 14 |
|---|---|---|---|
| superadas | omitidas | fallos | segundos |

**Despliegue verificado** el 26/09/2026, código de salida 0: tablas, llave, funciones, puerta de enlace y registro de actividad.

| | |
|---|---|
| **Condición** | Un secreto de firma quedó publicado en el repositorio durante 27 minutos |
| **Criterio** | ISO/IEC 27001 A.5.17 y A.8.4 |
| **Causa** | La exclusión existía y se retiró en bloque al versionar las evidencias |
| **Corrección** | Rotación, redespliegue de las ocho funciones, comprobación de rechazo y control C-09 |



## 8 · Evidencias y hallazgo principal · Oscar · ≈ 30 s

**Oscar:** Las evidencias: 234 pruebas superadas y ninguna fallida, sin credenciales, así que cualquiera puede repetirlas, y el despliegue verificado con código cero. El hallazgo más serio: el secreto que firma las sesiones quedó publicado 27 minutos; con él se podía firmar un token de administrador. Lo rotamos, redesplegamos y comprobamos que el viejo se rechaza. Ningún control cubría los secretos; hoy lo vigila C-09.

INDICACIÓN Decir el hallazgo despacio: es lo más fuerte del deck. Tener una terminal con `python -m pytest -q` lista por si piden ejecutarla.

SI PREGUNTAN Suite: 84 unitarias, 120 de extremo a extremo y 34 del programa de auditoría; las cuatro omitidas requieren condiciones que no existen en la ejecución local. La consulta pública responde 404 a propósito: pedir un envío que no existe y recibir «no existe» prueba que la petición cruzó la puerta de enlace y ejecutó la lógica. ¿Cómo saben que el secreto no se usó? En la ventana, las seis funciones con rutas protegidas no recibieron invocaciones y las otras dos solo las de nuestra verificación. Cada evidencia está en el repositorio con comando, salida y fecha: `evidencias-despliegue/20260926T232257Z-rotacion-secreto.txt`, `95-verificar.sh` y la ejecución de auditoría `…235724886Z-4f87a8`.

BLOQUE 7 · CONCLUSIONES Y MEJORAS

# Conclusiones y mejoras

- Los **nueve requisitos** se cumplen y pueden comprobarse
- **Tres verificaciones independientes** coinciden: pruebas, despliegue y auditoría externa
- Tres riesgos materializados, los tres gestionados

| Acción prioritaria | Responsable | Tiempo |
|---|---|---|
| **Reescribir el historial del repositorio** | Nicolás Torres | 2 horas |
| **Rol de ejecución por función** | Sergio Montoya | 1 semana · depende del entorno |
| **Validar con una empresa real** | Oscar Rincón | Un semestre |

**Limitaciones:** sin usuarios reales · mínimo privilegio incumplido · integridad por detección, no prevención.

`github.com/Serann10255/Rastro`



## 9 · Conclusiones y mejoras · Oscar · ≈ 30 s

**Oscar:** Los nueve requisitos se cumplen, y tres verificaciones independientes llegan a lo mismo sin depender de nuestra palabra. Lo prioritario: reescribir el historial, un rol por función y validar con una empresa real. No tuvimos usuarios reales, y frente a quien administra la cuenta la integridad detecta pero no impide. Las restricciones del entorno fueron el insumo del diseño. Muchas gracias.

INDICACIÓN Después de «gracias», callarse. No resumir otra vez.

SI PREGUNTAN Otras acciones, de prioridad media o baja: ancla externa de la bitácora (Sergio, tres semanas, depende del entorno), concurrencia en el encadenamiento (Nicolás, una semana) y derivación de contraseñas más resistente (Nicolás, una semana). El criterio de cierre de cada una está en el apartado 15.2 del documento. Sin cómputo persistente, la arquitectura es bajo demanda; con un entorno volátil, el despliegue es reproducible.